THIRD PARTY AND VENDOR RISK POLICY

POL-013 | Issued under the Information Management Framework

Document ID: POL-013
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer / Legal
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Third Party and Vendor Risk Policy
Document ID	POL-013
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owners	Chief Information Officer (CIO) and Legal
Custodian	Information Security / Procurement
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	GDPR Art. 28–29, 32, 44–49; HIPAA 45 CFR §164.308(b); 21 CFR Part 11; EU Annex 11 §4; SOX (ITGC); ISO/IEC 27001:2022 (A.5.19–A.5.22); ISO 27036

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes the requirements for identifying, assessing, and managing the risks introduced when [Company Name] engages third parties — vendors, suppliers, consultants, and service providers — who access [Company Name] systems, process [Company Name] data, or perform functions on [Company Name]'s behalf.

Third parties are one of the most significant and least controllable sources of information security risk. When a vendor's systems are compromised, or when a vendor mishandles data, the impact falls on [Company Name] — legally, regulatorily, and reputationally. [Company Name] cannot outsource its regulatory obligations to a vendor. A vendor processing personal data on [Company Name]'s behalf is processing it under [Company Name]'s legal responsibility. A vendor maintaining a GxP system must maintain it in a way that preserves its validated state.

The risk tier applied to a vendor is determined primarily by the criticality tier and regulatory flags of the systems they access or host. A vendor with administrative access to a Tier 1 GxP system receives the same level of scrutiny as that system itself — because the vendor's security posture is, in effect, part of that system's security posture.

> **IMPORTANT:** No third party may access [Company Name] systems, process [Company Name] data, or be given information classified as Sensitive or above, until the requirements of this Policy have been satisfied. There is no provisional or trial access exception. Procurement must engage Information Security before any vendor engagement that involves system access or data processing is agreed.

2. Scope

This Policy applies to all third-party relationships involving any of the following:

- Access to [Company Name] systems or networks — including remote access, on-site access, and access via APIs or integrations
- Processing of [Company Name] data — including personal data, GxP records, financial data, and Confidential or above classified information
- Hosting or operating systems on [Company Name]'s behalf — including SaaS, PaaS, IaaS, and managed service providers
- Maintaining, supporting, or modifying systems that hold [Company Name] data — including software vendors providing patches, upgrades, and configuration services
- Providing personnel (contractors, consultants) who work within [Company Name]'s technology environment

The Policy applies from the pre-engagement assessment stage through the full lifecycle of the vendor relationship to offboarding. It applies regardless of whether the third party is a large enterprise, a small specialist, or an individual consultant.

3. Vendor Risk Tiering

Vendors are assigned a risk tier based on the highest-risk system they access or the highest-sensitivity data they process. The vendor risk tier determines the depth of pre-engagement assessment, the contractual requirements, and the ongoing monitoring frequency.

Vendor Tier	Criteria	Examples
Tier A — Critical	Vendor hosts or has administrative access to a Tier 1 or GxP-flagged system. OR vendor processes Special Category personal data, PHI, or clinical trial participant data. OR vendor is a critical dependency in the supply chain for a regulated product or process.	LIMS provider with hosting; clinical data management platform; ERP managed service provider; GxP system validation consultant with system access.
Tier B — High	Vendor has access to a Tier 2 system or SOX-scoped system. OR vendor processes Confidential or Sensitive Personal Data (Tier 3/4) at scale. OR vendor provides infrastructure on which Tier 1/2 systems run.	HRMS SaaS provider; cloud infrastructure provider; QMS platform; SOC/SIEM managed service; penetration testing firm.
Tier C — Medium	Vendor has access to Tier 3 systems only. OR vendor processes Internal Use data. OR vendor provides personnel (contractors/consultants) working in the IT environment without system-level access.	Project management SaaS; IT staffing agency; software licence reseller with limited support access; non-critical SaaS tools.
Tier D — Low	Vendor has no access to [Company Name] systems and processes only publicly available or anonymised information. OR vendor provides physical goods or services with no technology component.	Office supply vendor; facilities management (no IT access); public relations agency with no data access.

NOTE: Vendor tier must be assessed at engagement initiation and reviewed whenever the scope of the vendor relationship changes. A Tier C vendor that is subsequently granted access to a Tier 1 system must be re-tiered to Tier A and the full Tier A requirements satisfied before the expanded access is granted.

4. Pre-Engagement Assessment Requirements

No vendor engagement involving system access or data processing may proceed without a completed pre-engagement assessment. The depth of assessment is determined by vendor tier.

Assessment Component	Tier A	Tier B	Tier C	Tier D
Information Security questionnaire (vendor's own controls)	Mandatory — detailed (ISO 27001 or NIST CSF aligned, minimum 50 questions)	Mandatory — standard (25+ questions)	Mandatory — abbreviated (15 questions)	Not required
Evidence of information security certification	ISO 27001 certification or SOC 2 Type II report required. GxP vendors: evidence of GxP compliance programme.	ISO 27001 or SOC 2 Type II required, or equivalent evidence	Self-attestation acceptable with spot-check	Not required
Penetration test results	Required — must be within 12 months	Required — must be within 24 months	Not required	Not required
GDPR compliance assessment (if personal data processed)	Full DPIA for the processing activity (SOP-004). DPA mandatory before engagement.	Data Processing Agreement (DPA) mandatory before engagement.	DPA mandatory if personal data processed.	Not applicable
HIPAA Business Associate Agreement	Mandatory if PHI processed	Mandatory if PHI processed	Mandatory if PHI processed	Not applicable
GxP vendor qualification	Full Vendor Qualification per Section 7. Evidence entered in VMF before system access granted.	Not required unless GxP system access	Not required	Not required
Financial and reputational due diligence	Required — assess vendor viability and reputation	Recommende d	Not required	Not required
Sub-processor / fourth-party mapping	Required — identify all sub-processors who	Required for key sub-processors	Not required	Not required

Assessment Component	Tier A	Tier B	Tier C	Tier D
	will access [Company Name] data			

Assessment findings are documented in the Vendor Risk Register. The Sponsor (the internal employee requesting the vendor engagement) is responsible for initiating the assessment. Information Security conducts the assessment and produces the assessment report. The CIO (Tier A) or Information Security (Tier B/C) approves engagement based on the assessment outcome.

5. Contractual and Legal Requirements

Contractual protections must be in place before any vendor access or data processing begins. The specific requirements depend on vendor tier and data types involved.

Contractual Requirement	Tier A	Tier B	Tier C	Applicable When
Information Security Schedule / Annex	Mandatory — detailed IS obligations including incident notification SLA, access controls, encryption standards, audit rights	Mandatory — standard IS schedule	Recommended	All tiers with system or data access
Data Processing Agreement (DPA)	Mandatory (GDPR Art. 28)	Mandatory if personal data processed	Mandatory if personal data processed	Any processing of EU/UK personal data
Business Associate Agreement (BAA)	Mandatory	Mandatory if PHI processed	Mandatory if PHI processed	Any processing of US PHI
Confidentiality / NDA	Mandatory before any data sharing	Mandatory	Mandatory	Before sharing Confidential or above information
Right to audit clause	Mandatory — [Company	Right to request	Spot-check	Tier A/B mandatory

Contractual Requirement	Tier A	Tier B	Tier C	Applicable When
	Name] right to conduct or commission security audit at reasonable notice (minimum annual for Tier A)	audit evidence	rights	
Incident notification SLA	Mandatory — vendor must notify [Company Name] within 24 hours of confirmed or suspected breach affecting [Company Name] data	48 hours	72 hours	All tiers with data access
Subprocessor restrictions	Mandatory — vendor must seek [Company Name] approval before engaging subprocessors with access to [Company Name] data	Prior written notice required	Notification required	All tiers processing personal data
Data return / destruction on termination	Mandatory — vendor must return or destroy all [Company Name] data within 30 days of termination, with written confirmation	Mandatory	Mandatory if personal data	All tiers with data access
Governing law and jurisdiction	Consistent with GDPR transfer restrictions — SCCs,	Same	Same	All cross-border personal data processing

Contractual Requirement	Tier A	Tier B	Tier C	Applicable When
	adequacy decision, or IDTA required for international transfers of EU/UK personal data			

6. Ongoing Vendor Monitoring

Vendor risk is not static. A vendor that passed pre-engagement assessment may experience a security breach, change ownership, expand sub-processor use, or undergo certification lapse. Ongoing monitoring ensures the risk profile remains current throughout the relationship.

Monitoring Activity	Tier A	Tier B	Tier C	Responsible
Annual vendor review (reassess risk, review controls evidence)	Annual — full reassessment including updated security evidence and re-execution of assessment questionnaire	Annual — standard review	Biennial	Information Security / Sponsor
SOC 2 Type II / ISO 27001 certificate renewal	Confirm annual renewal — gap in certification is a risk event requiring immediate assessment	Confirm on renewal cycle	Not required	Sponsor / Information Security
Vendor incident monitoring (public breach disclosures, CVE affecting vendor products)	Continuous — Information Security monitors threat intelligence feeds for Tier A vendor breach notifications	Periodic — reviewed at annual review	Not required	Information Security
Sub-processor change approval	Mandatory prior approval by [Company Name] before any sub-processor change	Notification + 30-day objection window	Notificatio n	Sponsor / Information Security
Access review (accounts, permissions)	Monthly for privileged accounts (per POL-009); quarterly for standard access (per	Quarterly	Annual	System Owner / Information Security

Monitoring Activity	Tier A	Tier B	Tier C	Responsible
	POL-008)			
Contract review (DPA, BAA, IS schedule currency)	At each annual review and on contract renewal	At contract renewal	At contract renewal	Legal / Information Security
Vendor financial health	Annual — flag vendors with viability risk for Tier A critical dependencies	On material adverse news	Not required	Procurement / CIO

6.1 Vendor Risk Register

Information Security maintains a Vendor Risk Register as part of the broader IS Risk Register (POL-010). The Vendor Risk Register records all in-scope vendor relationships with their assigned tier, assessment status, contractual status, and any open risk findings. It is reviewed at each ISSG meeting.

7. GxP Vendor Qualification (Tier A — GxP System Suppliers)

EU Annex 11 §4 and 21 CFR Part 11 require that computer system suppliers used in GxP activities are assessed for their suitability. A vendor supplying, hosting, or maintaining a GxP-validated system must be qualified before the system can be used for regulated activities, and that qualification must be maintained throughout the relationship.

Qualification Step	Description	Evidence in VMF
Vendor assessment	Assessment of the vendor's software development lifecycle (SDLC), quality management system, change control processes, and GxP compliance programme. Conducted using a supplier audit questionnaire and, for critical systems, an on-site or remote audit. The assessment confirms the vendor operates controls sufficient to deliver a product suitable for GxP use.	Vendor Assessment Report signed by Compliance / QA and System Owner.
Supplier agreement	A Technical Agreement (or equivalent) between [Company Name] and the vendor governing: the vendor's SDLC and validation obligations; notification	Executed Technical Agreement reference in VMF.

Qualification Step	Description	Evidence in VMF
	requirements for software updates and patches; support and maintenance SLAs; obligation to provide change documentation for all software changes affecting validated functionality; obligations on sub-contracting of GxP-relevant activities.	
Change notification	The vendor must notify [Company Name] of any planned changes to the validated system — software versions, infrastructure, configuration — in sufficient time for [Company Name] to conduct a validation impact assessment under POL-006 / POL-007 before the change is applied. Emergency changes by the vendor require the same POL-007 emergency change assessment retrospectively.	Vendor change notification records filed in VMF as change events.
Ongoing qualification maintenance	Vendor qualification is reviewed annually and updated whenever a major change occurs (new software version, change in hosting environment, change in vendor ownership or key personnel). A change in vendor that is material to the validated system is treated as a Major Impact change under POL-006 and may require re-qualification.	Annual Vendor Qualification Review record in VMF.
Dequalification / Offboarding	If a GxP system vendor relationship ends: a Validation Closure Report must be completed per POL-006 before the system is decommissioned or migrated to a new vendor. All VMF documentation must be archived per POL-002.	Validation Closure Report in VMF on offboarding.

GxP: Regulators assess vendor qualification during GxP inspections. The question 'how do you ensure your software supplier operates appropriate controls?' requires a documented vendor qualification file in the VMF, a Technical Agreement, and evidence of periodic review. A verbal response is not acceptable evidence.

8. International Data Transfers

Where a vendor processes personal data of EU or UK data subjects outside the EU/UK (or transfers it to a country without an adequacy decision), an appropriate transfer mechanism must be in place before the data transfer occurs. This is a legal prerequisite — not a contractual preference.

Transfer Mechanism	When Applicable
EU Standard Contractual Clauses (SCCs) (European Commission 2021 SCCs)	For transfers from the EU to third countries without an adequacy decision. SCCs are incorporated into the DPA. A Transfer Impact Assessment (TIA) is required for transfers to high-risk jurisdictions.
UK International Data Transfer Agreement (IDTA)	For transfers from the UK to countries without a UK adequacy decision. Required in addition to or instead of EU SCCs for UK personal data.
Adequacy decision	Where the destination country has an EU or UK adequacy decision in force, no additional mechanism is required. The DPO maintains the list of current adequacy decisions.
Binding Corporate Rules (BCRs)	For intra-group transfers within multinational vendor organisations that have ICO/DPA-approved BCRs. The vendor must provide evidence of current BCR approval.

The DPO is responsible for assessing the appropriateness of transfer mechanisms and for maintaining the Record of Processing Activities (ROPA) entries for cross-border processing. Legal must be engaged before any new international transfer mechanism is executed. No personal data transfer to a third country may begin until the transfer mechanism is documented and signed.

9. Vendor Offboarding

Vendor offboarding is a controlled process — not simply the expiry of a contract. The following steps must be completed for all Tier A and Tier B vendors, and adapted proportionately for Tier C:

Offboarding Step	Requirement	Responsible
Access revocation	All vendor accounts (user, service, API) are revoked by end of the final day of engagement. For privileged vendor accounts on Tier 1 systems: immediate revocation on confirmation of termination.	Information Security / Data Custodian (IT)

Offboarding Step	Requirement	Responsible
	Information Security confirms revocation within 24 hours.	
Credential rotation	Shared credentials or API keys used by the vendor are rotated immediately on offboarding. System passwords changed where vendor had access to shared system accounts.	Data Custodian (IT) / Information Security
Data return or destruction	Vendor returns or destroys all [Company Name] data per the contractual data return / destruction clause. Vendor provides written certification of destruction within 30 days.	Sponsor / Legal
GxP system validation closure	For Tier A GxP vendors: complete Validation Closure Report per POL-006 before system is decommissioned or transitioned to replacement vendor.	Compliance / QA / System Owner
DPA / BAA termination	Confirm that the DPA/BAA termination and data destruction provisions have been triggered and data destruction confirmation received. DPO signs off.	DPO / Legal
Vendor Risk Register update	Mark vendor as offboarded in Vendor Risk Register. Archive all assessment, audit, and contract documentation per POL-002 (7-year retention for SOX-scoped vendors; GxP retention for GxP-qualified vendors).	Information Security
Lessons learned	For Tier A vendors: conduct a brief post-relationship assessment — was the vendor's risk tier correct? Were there incidents or near-misses? Feed findings into Vendor Risk Register and procurement guidance.	Sponsor / Information Security

10. Third-Party Security Incidents

When a vendor experiences a security incident that affects or potentially affects [Company Name] data or system access, [Company Name] treats this as a security incident under POL-012. The vendor's notification SLA (Section 5) triggers [Company Name]'s own incident response process.

- On receiving a vendor breach notification: the Sponsor notifies Information Security immediately. Information Security assesses whether [Company Name] data or systems are affected.
- If [Company Name] data is confirmed or suspected to be affected: POL-012 incident process is initiated with the DPO notified for GDPR/HIPAA assessment. The 72-hour GDPR notification clock runs from [Company Name]'s awareness, not the vendor's notification date.
- If [Company Name] systems are affected: POL-012 IRT is activated; vendor access to [Company Name] systems is suspended pending investigation.
- For Tier A GxP vendors: Compliance / QA is notified immediately. Any vendor incident affecting a GxP system is assessed for impact on validated state per POL-006.
- Vendor breach notifications must be retained as part of the IS Risk Register and incorporated into the next annual vendor review.

11. Roles and Responsibilities

Role	Responsibility
CIO / Legal	Policy co-owners. CIO approves Tier A vendor engagements. Legal reviews and executes DPAs, BAAs, SCCs, and Technical Agreements. Legal assesses international transfer mechanisms.
Information Security	Conducts vendor risk assessments. Maintains Vendor Risk Register. Reviews assessment questionnaires. Confirms access revocation on offboarding. Monitors threat intelligence for Tier A vendor incidents.
Procurement	Engages Information Security before any vendor contract with system access or data processing scope. Does not execute vendor contracts without Information Security sign-off on risk assessment completion.
Sponsor	The internal employee requesting the vendor engagement. Initiates the risk assessment process. Takes accountability for the ongoing appropriateness of the vendor relationship. Notifies Information Security immediately on vendor incidents or scope changes.
DPO	Assesses GDPR compliance for all vendor engagements involving personal data. Reviews and countersigns DPAs. Maintains ROPA entries for vendor processing. Manages international transfer mechanism documentation. Signs off data destruction confirmation on offboarding.
Compliance / QA	Leads GxP vendor qualification. Signs off VMF documentation. Reviews Technical Agreements for GxP adequacy. Confirms validated state after vendor changes to GxP systems.
System Owner	Ensures vendor access to their system is within scope of the vendor risk assessment. Confirms access levels are consistent with the approved vendor tier. Conducts access reviews for vendor accounts per POL-008/POL-009.

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-001	Data Classification Policy	Classification of data shared with vendors determines vendor tier and contractual requirements
POL-004	Privacy Policy	GDPR Art. 28 DPA and HIPAA BAA requirements; international transfer mechanisms; DPIA for new processing activities by vendors
POL-005	System Classification Policy	System criticality tier and GxP/SOX flags are primary inputs to vendor risk tier assignment
POL-006	Computer System Validation and Qualification Policy	GxP vendor qualification is a VMF requirement; Technical Agreement and Supplier Assessment Report are VMF components; vendor change notification requirements feed the validation impact assessment process
POL-007	Change Management Policy	Vendor changes to GxP or Tier 1/2 systems are governed by POL-007; vendor change notifications trigger validation impact assessment; Technical Agreement must specify vendor change notification timelines
POL-008	Access Control Policy	Vendor user accounts are governed by POL-008 — named individual accounts, time-limited access, quarterly reviews for Tier A; offboarding access revocation
POL-009	Privileged Access Management Policy	Vendor privileged access is governed by POL-009 — session recording, supervision for Tier 1/GxP, time-limited activation only
POL-010	Information Security Risk Policy	Vendor risks are a distinct sub-category in the IS Risk Register; Material Tier A vendor risks are escalated to ISSG; vendor incidents create or update Risk Register entries
POL-012	Incident Response Policy	Vendor breach notifications trigger POL-012 IR process; 72-hour GDPR clock runs from [Company Name] awareness; vendor access suspended during investigation
POL-002	Data Retention and Disposal Policy	Vendor data destruction confirmation retained per POL-002; VMF vendor qualification records retained for GxP retention period; SOX vendor

Document ID	Title	Relationship
		records retained 7 years
SOP-004	Privacy Process	DPIA for new vendor processing activities; DPA template and negotiation guidance; international transfer assessment
EXC-001	Exception Management Policy and Register	Vendor engagement exceptions (e.g., limited access before full assessment) are high-risk under EXC-001 — require CISO approval and real-time session supervision; 6-month maximum; GxP vendor qualification exceptions require Compliance/QA and VMF documentation
RACI-001	Roles, Responsibilities and Authorities	Third party management accountability

13. Definitions

Term	Definition
BAA (Business Associate Agreement)	A contract required by HIPAA between a covered entity (or business associate) and a business associate that creates, receives, maintains, or transmits PHI on its behalf.
DPA (Data Processing Agreement)	A contract required by GDPR Article 28 between a controller and a processor, governing the terms under which the processor handles personal data on behalf of the controller.
Fourth Party	A sub-processor engaged by a vendor (third party) to perform processing activities on behalf of the vendor that involve [Company Name] data.
SCCs (Standard Contractual Clauses)	Contractual clauses approved by the European Commission for use as a legal basis for transfers of personal data from the EU to third countries without an adequacy decision.
SOC 2 Type II	A report produced by an independent auditor assessing a service organisation's controls relevant to security, availability, processing integrity, confidentiality, and privacy, over a defined period (typically 12 months).
Sponsor	The internal [Company Name] employee who requests a vendor engagement and takes accountability for the appropriateness and ongoing management of that relationship.
Technical Agreement	A GxP-specific agreement between a regulated company and a computer system supplier defining the supplier's obligations regarding software development, validation support, change management, and GxP compliance.
Transfer Impact Assessment (TIA)	An assessment conducted before transferring personal data to a third country under SCCs, evaluating whether the legal framework in the

Term	Definition
	destination country undermines the protection provided by the SCCs.
Vendor Qualification	The GxP-specific process of assessing and documenting a supplier's suitability to supply, maintain, or host a computer system used in regulated activities.

— End of Document —

POL-013 v1.0 DRAFT | [Company Name] | CONFIDENTIAL